

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Thu 28 May 2026, at 11:46:04

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(2\)](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Low, Confidence=Medium \(1\)](#)
 - [Risk=Informational, Confidence=Medium \(2\)](#)

- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `https://efbox.local:8081`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk	User	Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	2 (33.3%)	0 (0.0%)	2 (33.3%)
	Medium	0 (0.0%)	1 (16.7%)	0 (0.0%)	0 (0.0%)	1 (16.7%)
	Low	0 (0.0%)	0 (0.0%)	1 (16.7%)	0 (0.0%)	1 (16.7%)
	Informational	0 (0.0%)	0 (0.0%)	2 (33.3%)	0 (0.0%)	2 (33.3%)
	Total	0 (0.0%)	1 (16.7%)	5 (83.3%)	0 (0.0%)	6 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk

		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
https://efbox.local		2	1	1	2
Site	1:8081	(2)	(3)	(4)	(6)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection	High	1 (16.7%)
Spring4Shell	High	1 (16.7%)
Content Security Policy (CSP) Header Not Set	Medium	1 (16.7%)
Cookie without SameSite Attribute	Low	5 (83.3%)
Session Management Response Identified	Informational	20 (333.3%)
User Agent Fuzzer	Informational	5 (83.3%)
Total		6

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	5
Low	Warning		ZAP warnings logged - see the zap.log file for details	123
Low	Exceeded High	https://efbox.local:8081	Percentage of responses with status code 4xx	98 %
Low	Exceeded High	https://efbox.local:8081	Percentage of slow responses	52 %
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://efbox.local:8081	Percentage of responses with status code 4xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archiv	Percentage of slow responses	80 %

Level	Reason	Site	Description	Statistic
		e.mozila.org		
Info	Informational	https://efbox.local:8081	Percentage of responses with status code 2xx	1 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type application/json	39 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type application/vnd.openxmlformats-officedocument.wordprocessingml.document	2 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type text/html	2 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with content type text/plain	52 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method DELETE	15 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method GET	39 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method POST	21 %
Info	Informational	https://efbox.local:8081	Percentage of endpoints with method PUT	23 %
Info	Informational	https://efbox.local:8081	Count of total endpoints	38

Alerts

Risk=High, Confidence=Medium (2)

https://efbox.local:8081 (2)

SQL Injection (1)

▼ PUT https://efbox.local:8081/user/change-password

Alert tags

▪ POLICY_SEQUENCE =

- [OWASP_2021_A03](#)
- [PCI_DSS](#)
- [CWE-89](#)
- POLICY_QA_CICD =
- POLICY_DEV_CICD =
- [OWASP_2025_A05](#)
- [WSTG-v42-INPV-05](#)
- POLICY_API =
- POLICY_DEV_FULL =
- POLICY_QA_STD =
- POLICY_QA_FULL =
- POLICY_PENTEST =
- [HIPAA](#)
- [OWASP_2017_A01](#)
- [API_2023_API10](#)
- POLICY_DEV_STD =

**Alert
description**

SQL injection may be possible.

Other info

The page results were successfully manipulated using the boolean conditions [IlikeToMoveIT1990@' AND '1'='1' --] and [IlikeToMoveIT1990@' OR '1'='1' --]

The parameter value being modified was stripped from the HTML output for the purposes of the comparison.

Data was NOT returned for the original parameter.

The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.

Request

▼ Request line and header section (470 bytes)

```
PUT https://efbox.local:8081/user/
change-password HTTP/1.1
Content-Type: application/json
User-Agent: PostmanRuntime/7.54.0
```


Accept: */*
Postman-Token: d44f3f71-690c-4ac9-b740-220f304ea6f4
host: efbox.local:8081
Connection: keep-alive
content-length: 105
Cookie: efbox-
token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJhdXRoMCIsInN1YiI6ImZlZGQ0MmM1LTI0NDMtNDAwMC1hYjYzLTJkYmVmZDZmNDExNiIsImV4cCI6MTc3OTk2MTE2N30.qWh4Cb0uDs74QydyBI5742xDFFo1M54s33Jkd7VMuwY

▼ Request body (105 bytes)

```
{  
  "username": "DrAlban",  
  "newPassword":  
  "IlikeToMoveIT1990@" AND '1'='1'  
  -- ",  
  "code": 3446  
}
```

Response

▼ Status line and header section (450 bytes)

HTTP/1.1 429
X-Rate-Limit-Remaining: 0
Retry-After: 0
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store,
max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-
age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Type: application/
json; charset=ISO-8859-1
Content-Length: 32

Date: Thu, 28 May 2026 09:34:53 GMT
Keep-Alive: timeout=60
Connection: keep-alive

▼ Response body (32 bytes)

```
{"error": "Rate limit exceeded"}
```

Parameter

newPassword

Attack

IlikeToMoveIT1990@' OR '1'='1' --

Solution

Do not trust client side input, even if there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do **not** concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Spring4Shell (1)

► POST <https://efbox.local:8081>

Risk=Medium, Confidence=High (1)

<https://efbox.local:8081> (1)

Content Security Policy (CSP) Header Not Set (1)

▼ GET <https://efbox.local:8081/bossmang/fetch-all-logs>

Alert tags

- [OWASP_2021_A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-693](#)
- [OWASP_2017_A06](#)
- [OWASP_2025_A02](#)

Alert description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard

HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Request

▼ Request line and header section (420 bytes)

```
GET https://efbox.local:8081/
bossmang/fetch-all-logs HTTP/1.1
User-Agent: PostmanRuntime/7.54.0
Accept: */*
Postman-Token: c6e89ead-3d1a-414b-
a5c4-e8facd2accbb
host: efbox.local:8081
Connection: keep-alive
Cookie: efbox-
token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJhdXRoMCIsInN1YiI6IjYxNjMwZTAzLTExNTU0NGY0OC04MGNmLTlzMzM3MGYwNzc0NiIsImV4cCI6MTc3OTk1ODEzNX0.9W-fCsnkGGKD59Qch2-
Rn4TZnJ42lc_H3YzkvgD07Rs
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (398 bytes)

```
HTTP/1.1 201
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store,
max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-
age=31536000 ; includeSubDomains
X-Frame-Options: DENY
```

Content-Type: text/
html; charset=UTF-8
Content-Length: 24880
Date: Thu, 28 May 2026 08:46:23 GMT
Keep-Alive: timeout=60
Connection: keep-alive

► Response body (24880 bytes)

Solution

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Risk=Low, Confidence=Medium (1)

<https://efbox.local:8081> (1)

Cookie without SameSite Attribute (1)

► PUT <https://efbox.local:8081/user/login>

Risk=Informational, Confidence=Medium (2)

<https://efbox.local:8081> (2)

Session Management Response Identified (1)

► PUT <https://efbox.local:8081/user/login>

User Agent Fuzzer (1)

► PUT <https://efbox.local:8081/bossmang/grant-admin-status>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Spring4Shell

Source	raised by an active scanner (Spring4Shell)
CWE ID	78
WASC ID	20
Reference	▪ https://nvd.nist.gov/vuln/detail/CVE-2022-22965 ▪ https://www.rapid7.com/blog/post/2022/03/30/spring4shell-zero-day-vulnerability-in-spring-framework/ ▪ https://spring.io/blog/2022/03/31/spring-framework-rce-early-announcement/#vulnerability ▪ https://spring.io/security/cve-2022-22965/

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
---------------	--

- Reference**
- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

- Reference**
- <https://owasp.org/wstg>